THREAT INTELLIGENCE REPORT

Insurance & Financial Services Sector

APT Threat Landscape • MITRE ATT&CK TTP Analysis • Cross-APT Technique Overlap • Detection Recommendations

TLP:AMBER — Restricted to Threat Intelligence & Security Operations Teams

Intelligence Type	**Tactical | Operational | Strategic**
Sector Focus	Insurance (Underwriting, Reinsurance) | Banking | Investment | FinTech
Geographic Scope	Global — North America, Europe, Asia-Pacific, Middle East
Tools Used	SOCRadar.io (Threat Intelligence Platform) | MITRE ATT&CK | ATT&CK Navigator
APT Groups Profiled	7 APT Groups — Nation-State & Financially Motivated Threat Actors
Framework	MITRE ATT&CK Enterprise v19
Classification	**TLP:AMBER — Authorised Recipients Only**
Date	15 August 2026

7	4	15	3	1
APT Groups Profiled	Nation-States Identified	ATT&CK Tactics Covered	Sub-Sectors Assessed	Navigator Overlap Layer

Table of Contents

1. Executive Summary3
2. Intelligence Objectives & Responsibility Alignment4
3. Methodology — Intelligence Collection & Analysis Workflow5
4. Phase 1 — Sector & Region Scoping6
5. Phase 2 — APT Identification via SOCRadar.io7
6. Phase 3 — APT Threat Profiles (MITRE ATT&CK Research)8
   6.1 APT41 (Double Dragon) — China9
   6.2 LAZARUS GROUP — North Korea10
   6.3 KIMSUKY — North Korea11
   6.4 SANDWORM — Russia12
   6.5 FIN7 (Carbanak Group) — Financially Motivated13
   6.6 TA505 (Clop) — Financially Motivated14
   6.7 Scattered Spider (UNC3944) — Financially Motivated15
7. Phase 4 — MITRE ATT&CK Navigator: TTP Overlap Analysis16
   7.1 Individual APT Layers16
   7.2 Composite Overlap Layer & Heatmap17
   7.3 Highest-Priority Overlapping Techniques18
8. Detection Capability Recommendations20
9. Proactive Threat Hunting Use Cases22
10. Strategic Intelligence Assessment23
11. Key Findings24
12. Screenshot Evidence Index25

1. Executive Summary

This report presents the findings of a structured threat intelligence engagement targeting the insurance and financial services sector, conducted using the MITRE ATT&CK framework and the SOCRadar.io threat intelligence platform. The engagement was designed to fulfil three core threat intelligence responsibilities: leveraging MITRE ATT&CK to identify and analyse adversary tactics, techniques, and procedures (TTPs) to strengthen detection capabilities; developing a proactive threat hunting posture through intelligence-led identification of emerging attack paths and security gaps; and producing tactical, operational, and strategic threat intelligence specific to the insurance and financial services sectors.

Seven advanced persistent threat (APT) groups were identified, researched, and profiled: four nation-state actors (APT41, LAZARUS GROUP, KIMSUKY, SANDWORM) and three financially motivated threat actor clusters (FIN7/Carbanak, TA505/Clop, Scattered Spider/UNC3944). All seven groups have documented targeting of financial institutions, insurers, or adjacent sectors with high-impact operations including financial theft, ransomware deployment, data exfiltration, and critical infrastructure disruption.

The MITRE ATT&CK Navigator was used to create individual technique layers for each APT and generate a composite overlap layer — revealing that 12 of 15 ATT&CK tactic categories are shared by five or more of the seven profiled actors. This convergence has a direct operational implication: detection rules and hunting queries targeting the highest-overlap techniques will provide adversary-agnostic coverage effective against the majority of the identified threat landscape, regardless of which specific actor initiates an attack.

The report concludes with prioritised detection engineering recommendations, proactive threat hunting use cases specific to the financial services sector, and a strategic intelligence assessment of the evolving threat landscape.

2. Intelligence Objectives & Responsibility Alignment

This engagement was structured to provide direct evidence against three core threat intelligence responsibilities. The table below maps each responsibility to the specific activities and outputs produced in this report.

R1 **Use the MITRE ATT&CK framework to identify and analyse attacker TTPs and strengthen detection capabilities**

Activity	How This Report Satisfies R1
APT TTP Research	All 7 APT groups were researched against the MITRE ATT&CK Enterprise knowledge base — every technique was documented, categorised by tactic, and attributed to specific actor groups
ATT&CK Navigator Layers	Individual layers created per APT in the Navigator — providing a visual technique map per actor
Overlap Analysis	Composite overlay reveals shared techniques across actors — these are the highest-priority detection targets
Detection Recommendations	Section 8 translates the overlap analysis directly into SIEM detection rules, EDR queries, and alerting logic

R2 **Develop the Proactive Threat Hunting Initiative using intelligence and security tools to identify emerging threats, attack paths and vulnerabilities**

Activity	How This Report Satisfies R2
SOCRadar.io Intelligence Gathering	Used SOCRadar.io's threat actor database to proactively identify APTs operating in the financial services space — before incidents occur
Attack Path Identification	MITRE ATT&CK technique chains for each APT reveal the likely attack paths through financial sector environments
Hunting Use Cases	Section 9 provides four concrete threat hunting hypotheses derived directly from the TTP overlap findings
Emerging Threat Assessment	TA505/Clop and Scattered Spider are documented as recently active and rapidly evolving — providing early warning for security teams

R3 **Oversee collection and analysis of tactical, operational and strategic threat intelligence with focus on insurance and financial services**

Intelligence Layer	How This Report Delivers It
Tactical Intelligence	Specific MITRE ATT&CK technique IDs, CVSS-equivalent severity, IOC types, and tool signatures for each APT — directly actionable by SOC analysts and threat hunters

Operational Intelligence	Actor group profiles, campaign histories, targeting patterns, and sector-specific attack timelines — actionable by incident response and detection engineering teams
Strategic Intelligence	Section 10 provides a board-level assessment of the insurance and financial services threat landscape, motivational analysis, and long-term risk trajectory for executive and risk management audiences

3. Methodology — Intelligence Collection & Analysis Workflow

This engagement followed a four-phase intelligence lifecycle; a structured, repeatable methodology aligned with established threat intelligence frameworks (MITRE ATT&CK) that ensures findings are actionable, attributable, and audit-ready.

Phase	Activity	Method	Output
1	**Sector & Region Scoping**	Defined the target sector (insurance, banking, financial services sub-sectors) and geographic scope (global). Established intelligence requirements based on organisational risk profile.	Scope definition | Intelligence requirements document
2	**APT Identification via SOCRadar**	Queried SOCRadar.io threat actor database using sector and geographic filters. Reviewed actor profiles, campaign histories, and associated IOCs. Selected 7 high-relevance actors for deep analysis.	Shortlisted APT group list
3	**TTP Research via MITRE ATT&CK**	For each APT: researched all documented techniques on attack.mitre.org. Documented aliases, attack vectors, known tools (MITRE software entries), and recent campaign activity.	7 APT threat profiles with full TTP lists
4	**ATT&CK Navigator Overlap Analysis**	Created individual technique layers per APT in the MITRE ATT&CK Navigator. Generated composite overlap layer. Identified highest-overlap techniques as priority detection targets.	Navigator layers + overlap heatmap + detection recommendations

Intelligence Tiering — What Each Layer Delivers

Tactical: Individual technique IDs (e.g. T1566 — Phishing) with detection logic — used by SOC analysts in SIEM and EDR platforms

Operational: Actor group profiles, TTPs, and campaign timelines — used by threat hunters and detection engineers to build proactive search hypotheses

Strategic: Sector risk assessment, adversary motivational analysis, long-term threat trajectory — used by CISOs, risk managers, and board-level stakeholders for investment and policy decisions

4. Phase 1 — Sector & Region Scoping

4.1 Sector Definition

The following sub-sectors were included in scope, reflecting the full breadth of the insurance and financial services industry. Each sub-sector has distinct data assets, regulatory obligations, and threat attractiveness to different adversary motivations.

Sub-Sector	High-Value Data Assets	Primary Threat Motivation
Banking & Retail Finance	Account credentials, wire transfer systems, SWIFT network access, PII	Financial theft — direct fund transfer, credential theft, BEC
Insurance (Underwriting)	Policyholder PII, actuarial models, reinsurance contract data, claims data	Data exfiltration for competitive intelligence; ransomware for business disruption
Reinsurance	Global treaty data, catastrophe models, cross-insurer exposure data	Strategic espionage — understanding risk aggregation across the sector
Investment Management	Trading algorithms, client portfolio data, M&A intelligence, research	Financial theft; insider trading intelligence; strategic espionage
FinTech & Payment Processing	Payment card data, API keys, blockchain wallet credentials, transaction data	Financial theft — highest direct monetisation potential

4.2 Geographic Scope — Global Threat Landscape

A global scope was applied, reflecting that financial sector threats are inherently cross-border. Nation-state actors target financial institutions regardless of geography when intelligence or financial objectives demand it. The following regions were included in the SOCRadar filter:

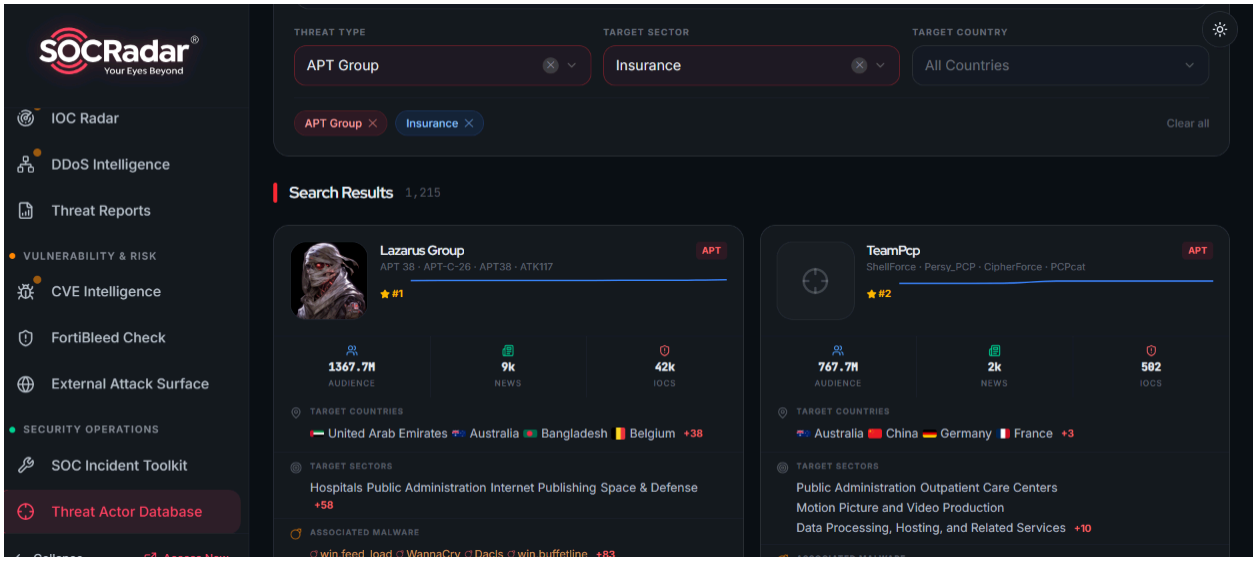
Region	Key Financial Centres	Primary Threat Actor Origin
North America	New York, Chicago, San Francisco, Toronto	North Korea (LAZARUS, KIMSUKY), China (APT41), Financially motivated (FIN7, TA505, Scattered Spider)
Europe	London, Frankfurt, Zurich, Amsterdam, Paris	Russia (SANDWORM), North Korea (LAZARUS), Financially motivated (TA505/Clop, FIN7)
Asia-Pacific	Tokyo, Hong Kong, Singapore, Sydney	China (APT41), North Korea (LAZARUS, KIMSUKY)
Middle East	Dubai, Riyadh, Tel Aviv	Suspected state-nexus actors; FIN7 and TA505 have documented regional presence
Global (All)	SWIFT network, CHIPS, correspondent banking	All actors — SWIFT is a cross-regional target

5. Phase 2 — APT Identification via SOCRadar.io

SOCRadar.io is a threat intelligence platform aggregating data from open, commercial, and dark web sources to provide curated threat actor profiles, campaign intelligence, and sector-specific threat feeds. In this engagement, SOCRadar's threat actor search was used to filter the global APT landscape to those with documented activity targeting the financial services and insurance sector.

5.1 SOCRadar Search Configuration

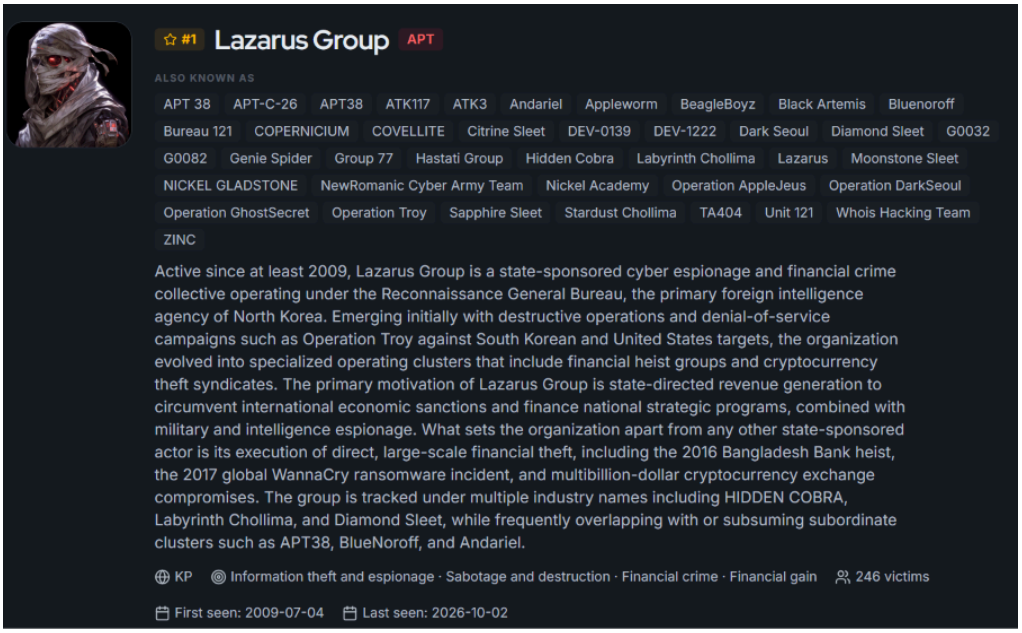
- Platform accessed: SOCRadar.io — Threat Actor Intelligence module
- Filter applied — Sector: Insurance
- Filter applied — Geography: Global (All Countries)
- Filter applied — Actor Type: APT Group
- Filter applied — Activity Status: Active (documented activity within the past 24 months)
- Result: [Insert count from your SOCRadar search] threat actors returned matching the filter criteria

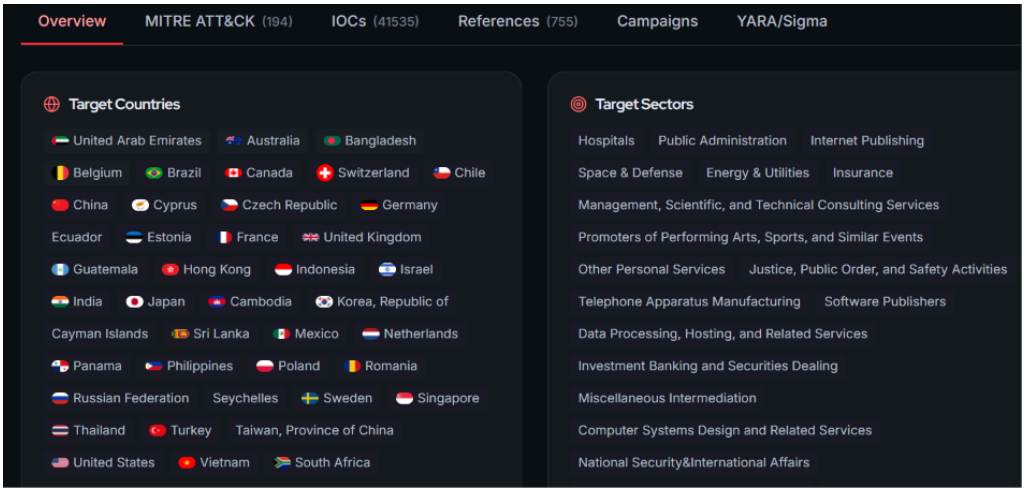


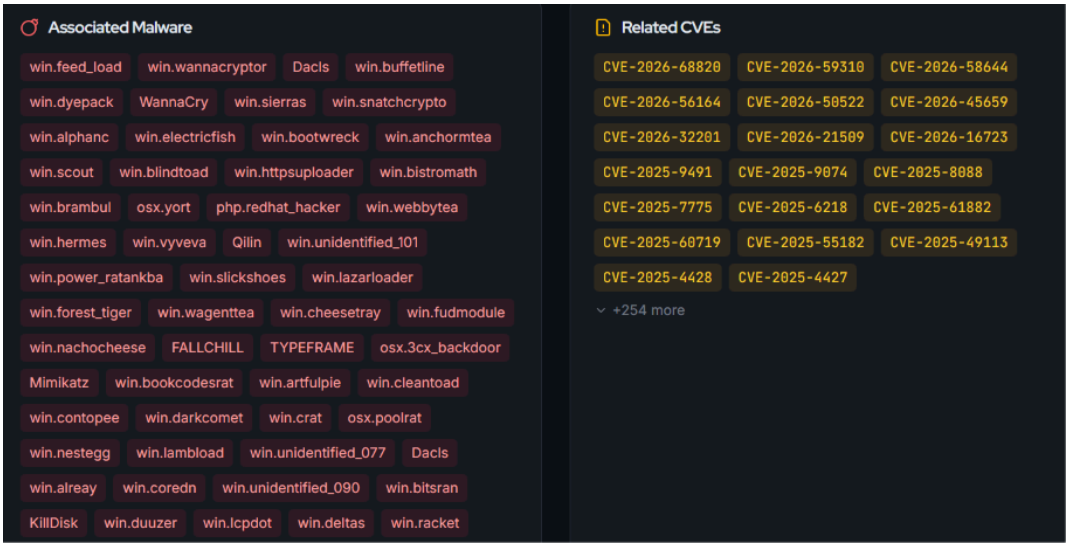
5.2 Shortlisting Methodology

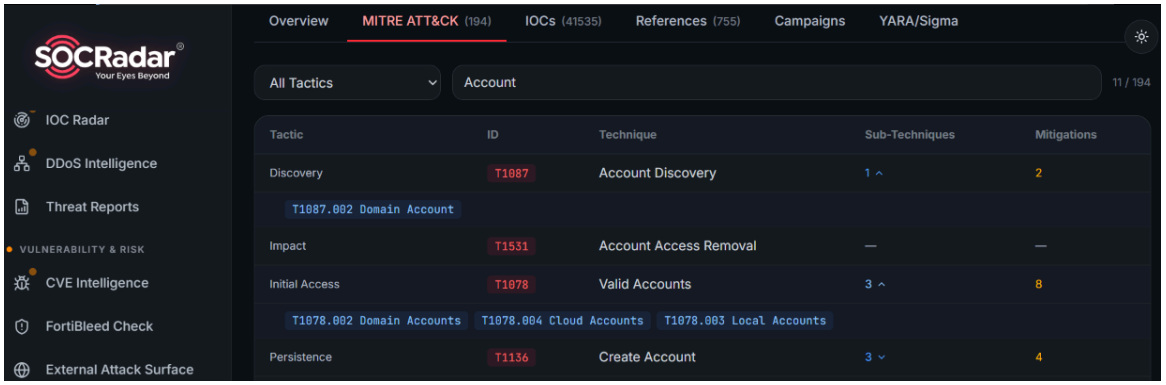
From the full SOCRadar result set, seven threat actors were selected for deep-dive analysis based on three prioritisation criteria:

- Documented financial sector targeting — actor has conducted confirmed operations against banks, insurers, or financial infrastructure
- Operational sophistication — actor uses advanced TTPs that represent realistic threats to a mature financial sector organisation (not script-kiddie level)
- Intelligence completeness — sufficient MITRE ATT&CK technique data available to enable meaningful TTP analysis and Navigator layer creation


#1
Lazarus Group
APT
ALSO KNOWN AS
APT 38
APT-C-26
APT38
ATK117
ATK3
Andariel
Appleworm
BeagleBoyz
Black Artemis
Bluenoroff
Bureau 121
COPERNICIUM
COVELLITE
Citrine Sleet
DEV-0139
DEV-1222
Dark Seoul
Diamond Sleet
G0032
G0082
Genie Spider
Group 77
Hastati Group
Hidden Cobra
Labyrinth Chollima
Lazarus
Moonstone Sleet
NICKEL GLADSTONE
NewRomanic Cyber Army Team
Nickel Academy
Operation AppleJeus
Operation DarkSeoul
Operation GhostSecret
Operation Troy
Sapphire Sleet
Stardust Chollima
TA404
Unit 121
Whois Hacking Team
ZINC
Active since at least 2009, Lazarus Group is a state-sponsored cyber espionage and financial crime collective operating under the Reconnaissance General Bureau, the primary foreign intelligence agency of North Korea. Emerging initially with destructive operations and denial-of-service campaigns such as Operation Troy against South Korean and United States targets, the organization evolved into specialized operating clusters that include financial heist groups and cryptocurrency theft syndicates. The primary motivation of Lazarus Group is state-directed revenue generation to circumvent international economic sanctions and finance national strategic programs, combined with military and intelligence espionage. What sets the organization apart from any other state-sponsored actor is its execution of direct, large-scale financial theft, including the 2016 Bangladesh Bank heist, the 2017 global WannaCry ransomware incident, and multibillion-dollar cryptocurrency exchange compromises. The group is tracked under multiple industry names including HIDDEN COBRA, Labyrinth Chollima, and Diamond Sleet, while frequently overlapping with or subsuming subordinate clusters such as APT38, BlueNoroff, and Andariel.
KP
Information theft and espionage · Sabotage and destruction · Financial crime · Financial gain
246 victims
First seen: 2009-07-04
Last seen: 2026-10-02


Overview
MITRE ATT&CK (194)
IOCs (41535)
References (755)
Campaigns
YARA/Sigma
Target Countries
United Arab Emirates
Australia
Bangladesh
Belgium
Brazil
Canada
Switzerland
Chile
China
Cyprus
Czech Republic
Germany
Ecuador
Estonia
France
United Kingdom
Guatemala
Hong Kong
Indonesia
Israel
India
Japan
Cambodia
Korea, Republic of
Cayman Islands
Sri Lanka
Mexico
Netherlands
Panama
Philippines
Poland
Romania
Russian Federation
Seychelles
Sweden
Singapore
Thailand
Turkey
Taiwan, Province of China
United States
Vietnam
South Africa
Target Sectors
Hospitals
Public Administration
Internet Publishing
Space & Defense
Energy & Utilities
Insurance
Management, Scientific, and Technical Consulting Services
Promoters of Performing Arts, Sports, and Similar Events
Other Personal Services
Justice, Public Order, and Safety Activities
Telephone Apparatus Manufacturing
Software Publishers
Data Processing, Hosting, and Related Services
Investment Banking and Securities Dealing
Miscellaneous Intermediation
Computer Systems Design and Related Services
National Security&International Affairs


Associated Malware
win.feed_load
win.wannacryptor
Dacls
win.buffetline
win.dyepack
WannaCry
win.sierras
win.snatchcrypto
win.alphanc
win.electricfish
win.bootwreck
win.anchormtea
win.scout
win.blindtoad
win.httpsuploader
win.bistromath
win.brambul
osx.yort
php.redhat_hacker
win.webbytea
win.hermes
win.vyveva
Qilin
win.unidentified_101
win.power_ratankba
win.slickshoes
win.lazarloader
win.forest_tiger
win.wagenttea
win.cheesetray
win.fudmodule
win.nachocheese
FALLCHILL
TYPEFRAME
osx.3cx_backdoor
Mimikatz
win.bookcodesrat
win.artfulpie
win.cleantoad
win.contopee
win.darkcomet
win.crat
osx.poolrat
win.nestegg
win.lambload
win.unidentified_077
Dacls
win.alreay
win.coredn
win.unidentified_090
win.bitsran
KillDisk
win.duuzer
win.lcpdot
win.deltas
win.racket
Related CVEs
CVE-2026-68820
CVE-2026-59310
CVE-2026-58644
CVE-2026-56164
CVE-2026-50522
CVE-2026-45659
CVE-2026-32201
CVE-2026-21509
CVE-2026-16723
CVE-2025-9491
CVE-2025-9074
CVE-2025-8088
CVE-2025-7775
CVE-2025-6218
CVE-2025-61882
CVE-2025-60719
CVE-2025-55182
CVE-2025-49113
CVE-2025-4428
CVE-2025-4427
+254 more



APT Group	Attribution	Primary Motivation	Financial Sector Relevance
APT41	**China (PRC)**	Espionage + Financial	Targets financial data for strategic intelligence; also conducts supply chain attacks on fintech
LAZARUS GROUP	**North Korea (DPRK)**	Financial theft	Primary DPRK financial theft arm — responsible for $3B+ in cryptocurrency theft; targeted SWIFT
KIMSUKY	**North Korea (DPRK)**	Espionage	Targets financial policy analysts, think tanks, and insurers for intelligence collection
SANDWORM	**Russia (GRU)**	Disruption	Targets financial infrastructure for geopolitical disruption; NotPetya caused $10B+ in financial sector losses
FIN7 (Carbanak)	**Criminal (Russia)**	Financial theft	Stole $1.2B+ from banking institutions; deploys point-of-sale malware, spear-phishing, and BEC
TA505 (Clop)	**Criminal**	Ransomware + Extortion	Prolific ransomware operator targeting financial institutions and insurers globally
Scattered Spider	**Criminal (UNC3944)**	Financial theft	Targets insurance companies and banks using advanced social engineering and MFA bypass

6. Phase 3 — APT Threat Profiles (MITRE ATT&CK Research)

For each of the seven shortlisted threat actors, a comprehensive threat profile was developed using MITRE ATT&CK as the primary research framework. Profiles were supplemented with public threat intelligence reporting from Mandiant, CrowdStrike, Microsoft MSTIC, US-CERT, and sector-specific ISACs (FS-ISAC).

6.1 APT41 — Double Dragon

APT41 | Also known as: Double Dragon, Winnti Group, Barium, Wicked Spider, HOODOO

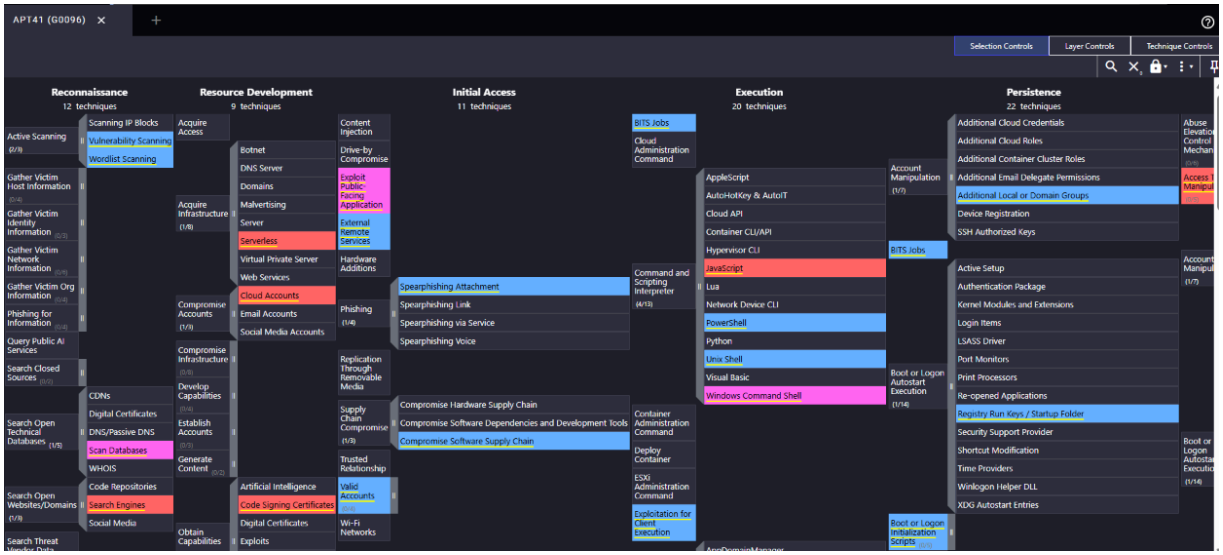
Nation-State Attribution: People's Republic of China — Ministry of State Security (MSS)

Motivation: Dual-mission: Espionage for Chinese state + financial gain (unique among state actors)

Primary Sectors Targeted: Financial Services, Healthcare, Telecommunications, Technology, Gaming, Government

Known Financial/Insurance Targeting: Targets financial institutions for IP theft and espionage; supply chain attacks on fintech vendors; cryptocurrency exchange targeting

Attribute	Detail	Financial Sector Implication
Known Tools	POISONPLUG, HIGHNOON, MESSAGETAP, ShadowPad, PlugX, Mimikatz, Cobalt Strike	Cobalt Strike and PlugX are widely detected in financial sector incidents — signatures are essential
Initial Access	Spearphishing, supply chain compromise, exploitation of public-facing applications	Financial sector VPN and Citrix appliances are primary targets
Financial Targeting	Cryptocurrency exchange targeting; financial sector espionage for M&A intelligence	Reinsurance firms' treaty data and M&A intelligence are high-value targets
Notable Operations	ShadowHammer supply chain (2019), COVID-19 research targeting (2020)	Demonstrates supply chain TTPs applicable to financial sector software vendors



APT41

APT41 is a threat group that researchers have assessed as Chinese state-sponsored espionage group that also conducts financially-motivated operations. Active since at least 2012, APT41 has been observed targeting various industries, including but not limited to healthcare, telecom, technology, finance, education, retail and video game industries in 14 countries.[1] Notable behaviors include using a wide range of malware and tools to complete mission objectives. APT41 overlaps at least partially with public reporting on groups including BARIUM and Winnti Group.[2][3]

ID: G0096

Associated Groups: Wicked Panda, Brass Typhoon, BARIUM

Contributors: Kyaw Pyiyt Htet, @KyawPyiytHtet; Nikita Rostovcev, Group-IB

Version: 4.2

Created: 23 September 2019

Last Modified: 31 July 2026

GROUPS

APT39
APT41
APT42
APT5
Aquatic Panda
Axiom
BackdoorDiplomacy
BITTER
BlackByte
BlackOasis
BlackTech
Blue Mockingbird
Bouncing Golf
BRONZE BUTLER
Carbanak
Chimera
Cinnamon Tempest
Cleaver
Cobalt Group
Confucius
Contagious Interview
CopyKittens
CURIUM
CyberAv3ngers
Daggerfly
Dark Caracal

Software

ID	Name	References	Techniques
S0073	ASPXSpy	[2]	Server Software Component: Web Shell
S0190	BITSAdmin	[8]	BITS Jobs, Exfiltration Over Alternative Protocol: Exfiltration Over Unencrypted Non-C2 Protocol, Ingress Tool Transfer, Lateral Tool Transfer
S0069	BLACKCOFFEE	[2]	Command and Scripting Interpreter: Windows Command Shell, File and Directory Discovery, Indicator Removal: File Deletion, Multi-Stage Channels, Process Discovery, Web Service: Dead Drop Resolver, Web Service: Bidirectional Communication
S0160	certutil	[9]	Archive Collected Data: Archive via Utility, Deobfuscate/Decode Files or Information, Ingress Tool Transfer, Subvert Trust Controls: Install Root Certificate
S0020	China Chopper	APT41 used the China Chopper web shell as a persistence mechanism on compromised Microsoft Exchange servers.[10][2]	Application Layer Protocol: Web Protocols, Brute Force: Password Guessing, Command and Scripting Interpreter: Windows Command Shell, Data from Local System, File and Directory Discovery, Indicator Removal: Timestomp, Ingress Tool Transfer, Network Service Discovery, Obfuscated Files or Information: Software Packing, Server Software Component: Web Shell
S0154	Cobalt Strike	[6][3]	Abuse Elevation Control Mechanism: Sudo and Sudo Caching, Abuse Elevation Control Mechanism: Bypass User Account Control, Access Token Manipulation: Parent PID Spoofing, Access Token Manipulation: Token Impersonation/Theft, Access Token Manipulation: Make and Impersonate Token, Account Discovery: Domain Account, Application Layer Protocol: DNS, Application Layer Protocol: Web Protocols, Application Layer Protocol: File Transfer Protocols, BITS Jobs, Browser Session Hijacking, Command and Scripting Interpreter: JavaScript, Command and Scripting Interpreter: Visual Basic, Command and Scripting Interpreter: PowerShell, Command and Scripting Interpreter: Python, Command and Scripting Interpreter: Windows Command Shell, Create or Modify System Process: Windows Service, Data Encoding: Standard Encoding, Data from Local System, Data Obfuscation: Protocol or Service Impersonation, Data Transfer Size Limits, Deobfuscate/Decode Files or Information, Disable or Modify Tools, Encrypted Channel: Asymmetric Cryptography, Encrypted Channel: Symmetric Cryptography, Exploitation for Client Execution, Exploitation for Privilege Escalation, File and Directory Discovery, Hide Artifacts: Process Argument Spoofing, Indicator Removal: Timestomp, Ingress Tool Transfer, Input Capture: Keylogging, Modify Registry, Native API, Network Service Discovery, Network Share Discovery, Non-Application Layer Protocol, Obfuscated Files or Information: Indicator Removal from Tools, Obfuscated Files or Information, Office Application Startup: Office Template Macros, OS Credential Dumping: LSASS Memory, OS Credential Dumping: Security Account Manager, Permission Groups Discovery: Domain Groups, Permission Groups Discovery: Local Groups, Process Discovery, Process Injection: Dynamic-link Library Injection, Process Injection: Process Hollowing, Process Injection, Protocol Tunneling, Proxy: Domain Fronting, Proxy: Internal Proxy, Query Registry, Reflective Code Loading, Remote Services: Remote Desktop Protocol, Remote Services: SSH, Remote Services: Windows Remote Management, Remote Services: SMB/Windows Admin Shares, Remote Services: Distributed Component Object Model, Remote System Discovery, Scheduled Transfer, Screen Capture, Software Discovery, Subvert Trust Controls: Code Signing, System Binary Proxy Execution: Rundll32, System Network Configuration Discovery, System Network Connections Discovery, System Service Discovery, System Services: Service Execution, Use Alternate Authentication Material: Pass the Hash, Valid Accounts: Domain Accounts, Valid Accounts: Local Accounts, Virtualization/Sandbox Evasion: User Activity Based Checks, Windows Management Instrumentation
S1052	DEADEYE	[7]	Command and Scripting Interpreter: Windows Command Shell, Deobfuscate/Decode Files or Information, Execution Guardrails, Hide Artifacts: NTFS File Attributes, Masquerading: Masquerade Task or Service, Native API, Obfuscated Files or Information: Encrypted/Encoded File, Obfuscated Files or Information: Embedded Payloads, System Binary Proxy Execution: Msiexec, System Binary Proxy Execution: Rundll32, System Information Discovery, System Network Configuration Discovery

6.2 LAZARUS GROUP — Hidden Cobra

LAZARUS GROUP | Also known as: Hidden Cobra, Zinc, APT38, Stardust Chollima, BeagleBoyz

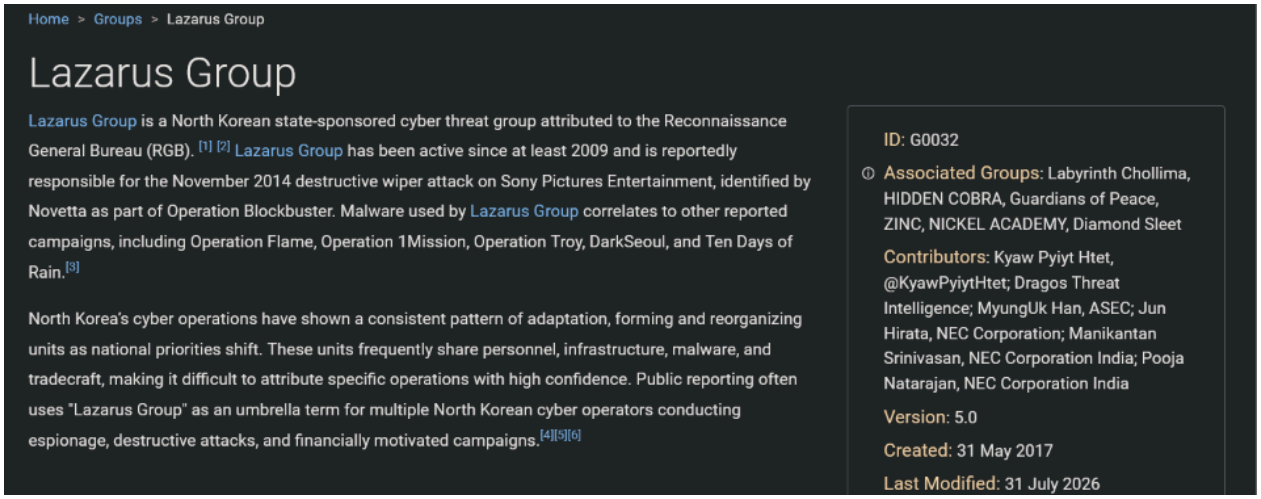
Nation-State Attribution: Democratic People's Republic of Korea (DPRK) — Bureau 121, Reconnaissance General Bureau

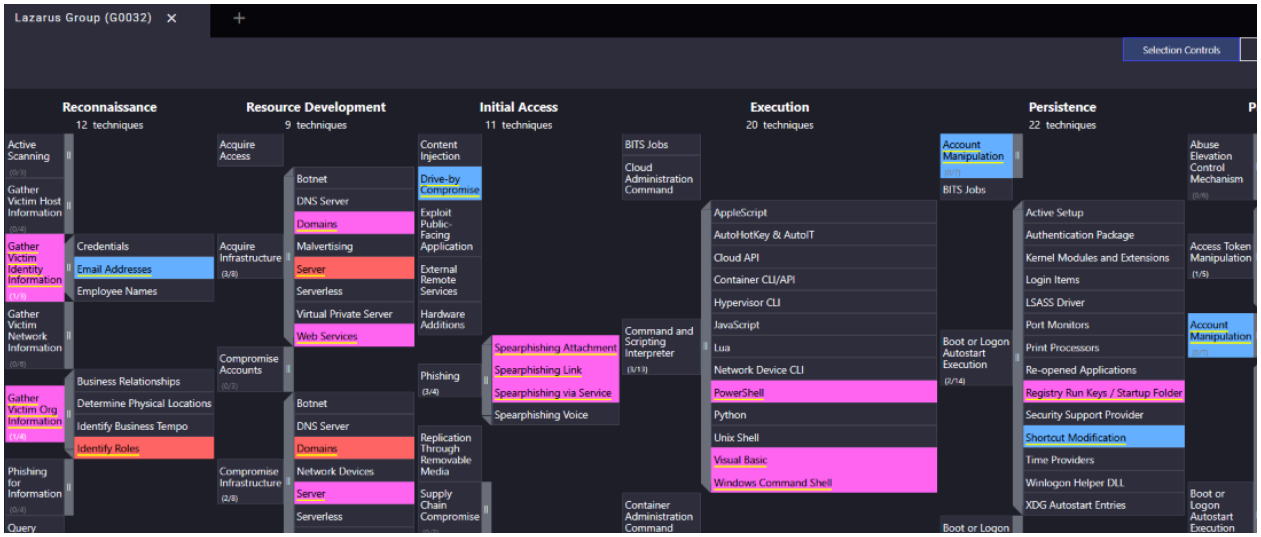
Motivation: Primary motivation: Financial theft to circumvent international sanctions — responsible for billions in financial crime

Primary Sectors Targeted: Banking, Financial Services, Cryptocurrency, Defence, Government

Known Financial/Insurance Targeting: Bangladesh Bank SWIFT heist ($81M, 2016); multiple cryptocurrency exchange compromises; targeting of FS-ISAC member institutions

Attribute	Detail	Financial Sector Implication
Known Tools	BLINDINGCAN, HOPLIGHT, AppleJeus (macOS/Linux), custom SWIFT malware, WannaCry	Custom SWIFT network malware represents direct targeting of interbank payment systems
Attack Vector	Spearphishing (job offer lures), trojanised software, social engineering of financial staff	Job offer LinkedIn lures specifically target finance professionals — widely reported tactic
Financial Operations	Bangladesh SWIFT ($81M), FASTCash ATM attacks, crypto exchange compromises ($3B+)	Demonstrates operational capability to execute large-scale financial transfers and exfiltration
Notable Operations	Sony Pictures (2014), WannaCry (2017), multiple crypto heists (2018-2024)	Cross-platform capability (Windows/Linux/macOS) covers all financial sector endpoint types





Software

ID	Name	References	Techniques
S0584	AppleJeus	[18]	Abuse Elevation Control Mechanism: Bypass User Account Control, Application Laye Protocol: Web Protocols, Command and Scripting Interpreter: Unix Shell, Create or Modify System Process: Windows Service, Create or Modify System Process: Launc Daemon, Deobfuscate/Decode Files or Information, Event Triggered Execution: Installer Packages, Exfiltration Over C2 Channel, Hide Artifacts: Hidden Files and Directories, Indicator Removal: File Deletion, Obfuscated Files or Information, Phishing: Spearphishing Link, Scheduled Task/Job: Scheduled Task, Subvert Trust Controls: Code Signing, System Binary Proxy Execution: Msiexec, System Informatio Discovery, System Services: Launchctl, User Execution: Malicious File, User Execution: Malicious Link, Virtualization/Sandbox Evasion: Time Based Checks
S0347	AuditCred	[41]	Command and Scripting Interpreter: Windows Command Shell, Create or Modify System Process: Windows Service, Deobfuscate/Decode Files or Information, File and Directory Discovery, Indicator Removal: File Deletion, Ingress Tool Transfer, Obfuscated Files or Information: Encrypted/Encoded File, Process Injection, Proxy
S0245	BADCALL	[42]	Data Obfuscation: Protocol or Service Impersonation, Disable or Modify System Firewall: Windows Host Firewall, Encrypted Channel: Symmetric Cryptography, Modi Registry, Non-Standard Port, Proxy, System Information Discovery, System Network Configuration Discovery

6.3 KIMSUKY — Velvet Chollima

KIMSUKY | Also known as: Velvet Chollima, Black Banshee, APT43, Thallium, TA406

Nation-State Attribution: Democratic People's Republic of Korea (DPRK) — Reconnaissance General Bureau

Motivation: Intelligence collection — economic and financial policy intelligence to support DPRK sanctions evasion strategy

Primary Sectors Targeted: Government, Think Tanks, Financial Policy Analysts, Insurance, Academics

Known Financial/Insurance Targeting: Targets financial policy researchers, SWIFT system analysts, FS-ISAC members; insurance sector for policy intelligence

Attribute	Detail	Financial Sector Implication
Known Tools	BabyShark, AppleSeed, PEBBLEDASH, Gold Dragon, Kimjongrat	BabyShark macro-based delivery is effective against financial staff who regularly process documents
Attack Vector	Highly targeted spearphishing — impersonates academics, journalists, and policy researchers	Insurance professionals receiving policy research emails are direct targets
Sector Focus	Financial regulators, central bank analysts, insurance sector policy staff	Insurance industry subject matter experts on sanctions, reinsurance, and financial policy are at risk
OPSEC	Long-dwell reconnaissance — KIMSUKY often maintains passive presence for months before acting	Financial sector dwell time before detection averages 197 days — KIMSUKY exploits this

6.4 SANDWORM — Voodoo Bear

SANDWORM | Also known as: Voodoo Bear, IRIDIUM, Seashell Blizzard, TeleBots, Olympic Destroyer

Nation-State Attribution: Russian Federation — GRU Unit 74455 (Main Centre for Special Technologies)

Motivation: Geopolitical disruption, economic sabotage, psychological operations in support of Russian foreign policy

Primary Sectors Targeted: Critical Infrastructure, Energy, Financial Services, Government, Media

Known Financial/Insurance Targeting: NotPetya (2017) caused $10B+ losses to financial sector; targeting of Ukrainian financial infrastructure; disruption of payment systems

Attribute	Detail	Financial Sector Implication
Known Tools	NotPetya, BlackEnergy, Industroyer, Olympic Destroyer, Cyclops Blink	NotPetya's financial sector impact ($10B+) demonstrates that geopolitical malware has collateral financial consequences
Attack Vector	Supply chain compromise, exploitation of network perimeter devices, watering holes	Financial sector's dependence on third-party software makes it vulnerable to SANDWORM supply chain TTPs
Financial Impact	NotPetya disrupted Maersk, DHL, and multiple financial institutions — not direct targets but collateral	Insurance sector absorbed billions in NotPetya claims — understanding SANDWORM TTPs is essential for underwriters
Escalation Risk	Conflict escalation in Europe triggers increased SANDWORM activity against Western financial institutions	Financial sector BCPs must account for geopolitical-trigger attack scenarios

6.5 FIN7 / Carbanak Group

FIN7 | Also known as: Carbanak, Carbon Spider, Sangria Tempest, ELBRUS, Navigator Group

Nation-State Attribution: Criminal Organisation — Russian-language, suspected Eastern European nexus

Motivation: Pure financial gain — bank robbery at scale using cyber techniques

Primary Sectors Targeted: Banking, Retail, Hospitality, Financial Services, Insurance (for PII monetisation)

Known Financial/Insurance Targeting: Carbanak campaign: $1.2B stolen from 100+ banks across 30 countries; targets insurance PII databases for identity fraud

Attribute	Detail	Financial Sector Implication
Known Tools	Carbanak malware, Cobalt Strike, Anunak, DICELOADER, PowerShell Empire	Cobalt Strike is the most commonly detected tool in financial sector incident response — FIN7 is primary deployer
Attack Vector	Spearphishing with malicious Office documents; business email compromise; insider recruitment	BEC and financial wire transfer fraud are direct financial institution risks
Financial Operations	Carbanak: $1.2B from banks; ongoing retail POS malware campaigns; ransomware deployment	Insurance sector holds PII that FIN7 monetises through identity fraud — direct targeting risk
Adaptation	FIN7 evolved from bank targeting to ransomware as a service — demonstrates threat actor adaptability	Detection rules must account for both financial theft TTPs and ransomware deployment chain

6.6 TA505 / Clop Ransomware Group

TA505 | Also known as: Clop, EVIL CORP nexus, Hive0065, SectorJ04

Nation-State Attribution: Criminal Organisation — financially motivated ransomware-as-a-service operator

Motivation: Ransomware deployment and data extortion targeting high-revenue organisations

Primary Sectors Targeted: Banking, Financial Services, Insurance, Healthcare, Retail

Known Financial/Insurance Targeting: Clop ransomware has impacted multiple insurance companies; MOVEit Transfer exploitation (2023) exposed 1000+ organisations including financial institutions

Attribute	Detail	Financial Sector Implication
Known Tools	Clop ransomware, FlawedAmmyy, SdBot, Cobalt Strike, MOVEit exploitation	MOVEit exploitation (CVE-2023-34362) impacted financial sector file transfer infrastructure at massive scale
Attack Vector	Mass exploitation of file transfer software (MOVEit, GoAnywhere), phishing, malvertising	Financial sector's reliance on managed file transfer (MFT) solutions is a systemic vulnerability
Financial Impact	MOVEit campaign: 600+ organisations breached; multiple insurance and banking victims confirmed	TA505 specifically identifies high-value targets (insurance, banking) for maximum ransom leverage
Extortion Model	Double extortion: encrypt and threaten to publish sensitive financial/insurance data publicly	Insurance companies' regulatory data (policy details, claims) have high extortion value

6.7 Scattered Spider / UNC3944

Scattered Spider | Also known as: UNC3944, 0ktapus, Muddled Libra, Starfraud

Nation-State Attribution: Criminal Organisation — English-speaking, largely Western nexus (US/UK threat actors)

Motivation: Financial theft, data extortion, SIM swapping, cryptocurrency theft targeting insurance and financial sector

Primary Sectors Targeted: Insurance, Telecommunications, Financial Services, Retail, Gaming

Known Financial/Insurance Targeting: Confirmed attacks against insurance companies including MGM Resorts (cyber insurance implications); targets financial sector identity systems

Attribute	Detail	Financial Sector Implication
Known TTPs	Advanced social engineering, MFA bypass, SIM swapping, identity provider abuse, Okta exploitation	Insurance companies' identity and access management (IAM) systems are primary targets
Attack Vector	Voice phishing (vishing) of IT helpdesk staff; impersonation of employees; Okta/AAD exploitation	Financial sector helpdesk social engineering is a critical and underestimated attack vector

Insurance Focus	MGM Resorts attack exposed cyber insurance claims process; targets insurance identity databases	Insurance companies are both direct targets and participants in the financial ecosystem around breach response
Detection Challenge	English-speaking, culturally aware — evades common detection heuristics based on non-English OPSEC	Traditional detection approaches fail against native English-speaking social engineers

Home > Groups > FIN7

FIN7

FIN7 is a financially-motivated threat group that has been active since 2013. FIN7 has targeted the retail, restaurant, hospitality, software, consulting, financial services, medical equipment, cloud services, media, food and beverage, transportation, pharmaceutical, and utilities industries in the United States. A portion of FIN7 was operated out of a front company called Combi Security and often used point-of-sale malware for targeting efforts. Since 2020, FIN7 shifted operations to big game hunting (BGH), including use of REvil ransomware and their own Ransomware-as-a-Service (RaaS), Darkside. FIN7 may be linked to the Carbanak Group, but multiple threat groups have been observed using Carbanak, leading these groups to be tracked separately.[1][2][3][4][5][6][7]

ID: G0046
Associated Groups: GOLD NIAGARA, ITG14, Carbon Spider, ELBRUS, Sangria Tempest
Contributors: Edward Millington; Eric Loui, CrowdStrike Intelligence; Serhii Melnyk, Trustwave SpiderLabs
Version: 4.1
Created: 31 May 2017
Last Modified: 31 July 2026

Version Permalink

Techniques Used

ATT&CK® Navigator Layers

Domain	ID		Name	Use
Enterprise	T1087	.002	Account Discovery: Domain Account	FIN7 has used the PowerShell script 3CF9.ps1 and the executable WsTaskLoad to enumerate domain administrations by executing `net group "Domain Admins" /domain`.[12] FIN7 has also used csvde.exe, which is a built-in Windows command line tool, to export Active Directory information.
Enterprise	T1583	.001	Acquire Infrastructure: Domains	FIN7 has registered look-alike domains for use in phishing campaigns.[13] Additionally, FIN7 has registered a malicious domain as `advanced-ip-sccanner[.]com` that redirected to an adversary-controlled Dropbox which contained the malicious executable.[12]
		.006	Acquire Infrastructure: Web Services	FIN7 has set up Amazon S3 buckets to host trojanized digital products.[6]
Enterprise	T1071	.004	Application Layer Protocol: DNS	FIN7 has performed C2 using DNS via A, OPT, and TXT records.[4]
Enterprise	T1547	.001	Boot or Logon Autostart Execution: Registry Run Keys / Startup Folder	FIN7 malware has created Registry Run and RunOnce keys to establish persistence, and has also added items to the Startup folder.[2][4]

TA505

TA505 is a cyber criminal group that has been active since at least 2014. TA505 is known for frequently changing malware, driving global trends in criminal malware distribution, and ransomware campaigns involving Clop.[1][2][3][4][5]

ID: G0092
Associated Groups: Hive0065, Spandex Tempest, CHIMBORAZO
Version: 3.0
Created: 28 May 2019
Last Modified: 31 July 2026

Techniques Used

ATT&CK® Navigator Layers

Domain	ID		Name	Use
Enterprise	T1087	.003	Account Discovery: Email Account	TA505 has used the tool EmailStealer to steal and send lists of e-mail addresses to a remote server.[8]
Enterprise	T1583	.001	Acquire Infrastructure: Domains	TA505 has registered domains to impersonate services such as Dropbox to distribute malware.[5]
Enterprise	T1071	.001	Application Layer Protocol: Web Protocols	TA505 has used HTTP to communicate with C2 nodes.[6]
Enterprise	T1059	.001	Command and Scripting Interpreter: PowerShell	TA505 has used PowerShell to download and execute malware and reconnaissance scripts.[1][9][10][11]
		.003	Command and Scripting Interpreter: Windows Command Shell	TA505 has executed commands using `cmd.exe`.[8]

Home > Groups > Scattered Spider

Scattered Spider

Scattered Spider is a native English-speaking cybercriminal group active since at least 2022. [1] [2] The group initially targeted customer relationship management (CRM) providers, business process outsourcing (BPO) firms, and telecommunications and technology companies before expanding in 2023 to gaming, hospitality, retail, managed service provider (MSP), manufacturing, and financial sectors. [2]
Scattered Spider relies heavily on social engineering, including impersonating IT and help-desk staff, to gain initial access, bypass multi-factor authentication (MFA), and compromise enterprise networks. The group has adapted its tooling to evade endpoint detection and response (EDR) defenses and used ransomware for financial gain. [3] [4] [5]
Scattered Spider had expanded into hybrid cloud and identity environments, using help-desk impersonation and MFA bypass to obtain administrator access in Okta, AWS, and Office 365. [6]

ID: G1015
Associated Groups: Roasted 0ktapus, Octo Tempest, Storm-0875, UNC3944
Version: 3.0
Created: 05 July 2023
Last Modified: 31 July 2026

Version Permalink

Techniques Used

ATT&CK® Navigator Layers

Domain	ID		Name	Use
Enterprise	T1087		Account Discovery	Scattered Spider has identified vSphere administrator accounts.[8]
		.002	Domain Account	Scattered Spider has enumerated legitimate domain accounts which are used in the targeted environment.[3][2][9][8]
		.003	Email Account	During C0027, Scattered Spider accessed Azure AD to identify email addresses.[5]
		.004	Cloud Account	During C0027, Scattered Spider accessed Azure AD to download bulk lists of group members and to identify privileged users, along with the email addresses and AD attributes.[5]
Enterprise	T1098		Account Manipulation	Scattered Spider has added accounts to the ESX Admins group to grant them full admin rights in vSphere.[8]
		.001	Additional Cloud Credentials	During C0027, Scattered Spider used aws_consoler to create temporary federated credentials for fake users in order to obfuscate which AWS credential is compromised and enable pivoting from the AWS CLI to console sessions without MFA.[5]
		.003	Additional Cloud Roles	Scattered Spider has assigned user access admin roles in order to gain Tenant Root Group management permissions in Azure.[2] During C0027, Scattered Spider used IAM manipulation to gain persistence and to assume or elevate privileges.[5]

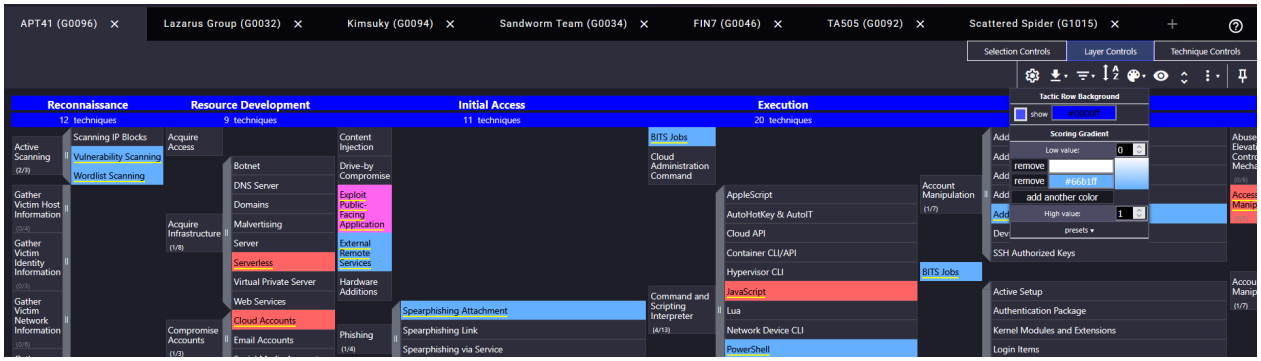
7. Phase 4 — MITRE ATT&CK Navigator: TTP Overlap Analysis

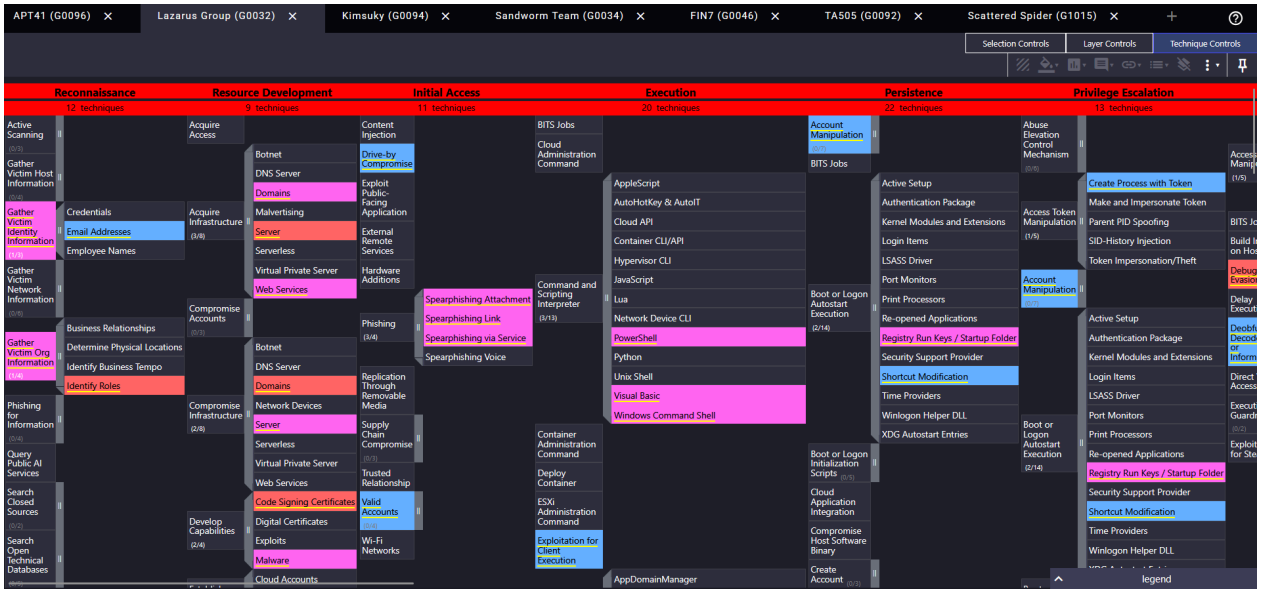
The MITRE ATT&CK Navigator was used to create individual technique layers for all seven APT groups, then generate a composite overlap layer. This is the analytical centrepiece of the threat intelligence engagement — it directly answers the question: 'Which detection controls will provide the broadest coverage against the greatest number of threats we face?'

7.1 Individual APT Layers

A separate ATT&CK Navigator layer was created for each of the seven APT groups. Each layer colour-codes the full set of MITRE ATT&CK techniques documented for that actor — providing a visual map of that actor's complete attack surface within the ATT&CK matrix.

Layer Name	APT Group	MITRE Group ID	Layer Colour / Notes
Layer 1 — APT41	APT41	G0096	Blue — dual-mandate espionage + financial TTPs
Layer 2 — LAZARUS	LAZARUS GROUP	G0032	Red — financial theft focus; extensive SWIFT targeting techniques
Layer 3 — KIMSUKY	KIMSUKY	G0094	Orange — intelligence collection; long-dwell techniques prominent
Layer 4 — SANDWORM	SANDWORM	G0034	Purple — destructive techniques; wiper and ICS techniques included
Layer 5 — FIN7	FIN7	G0046	Green — financial theft; POS malware and BEC techniques
Layer 6 — TA505	TA505	G0092	Dark red — ransomware chain; exfiltration and encryption techniques
Layer 7 — Scattered Spider	Scattered Spider	G1015	Teal — identity abuse; social engineering and IAM techniques





7.2 Composite Overlap Layer & Heatmap

The composite overlap layer was created by combining all seven individual APT layers and scoring each technique by the number of actors that employ it. The resulting heatmap colour-codes every technique by overlap score — darker colours indicate techniques used by more actors, and therefore represent higher-priority detection targets.

How to Read the Overlap Heatmap

Score 1 (light): Technique used by 1 actor — monitor

Score 2-3 (medium): Technique used by 2-3 actors — detect

Score 4-5 (dark): Technique used by 4-5 actors — alert

Score 6-7 (darkest / critical): Technique used by 6-7 actors — HIGHEST PRIORITY detection + automated response

Any technique scoring 5 or higher represents a control that, if detected, will fire against the majority of the identified threat landscape — making it the highest return-on-investment detection investment.



7.3 Highest-Priority Overlapping Techniques

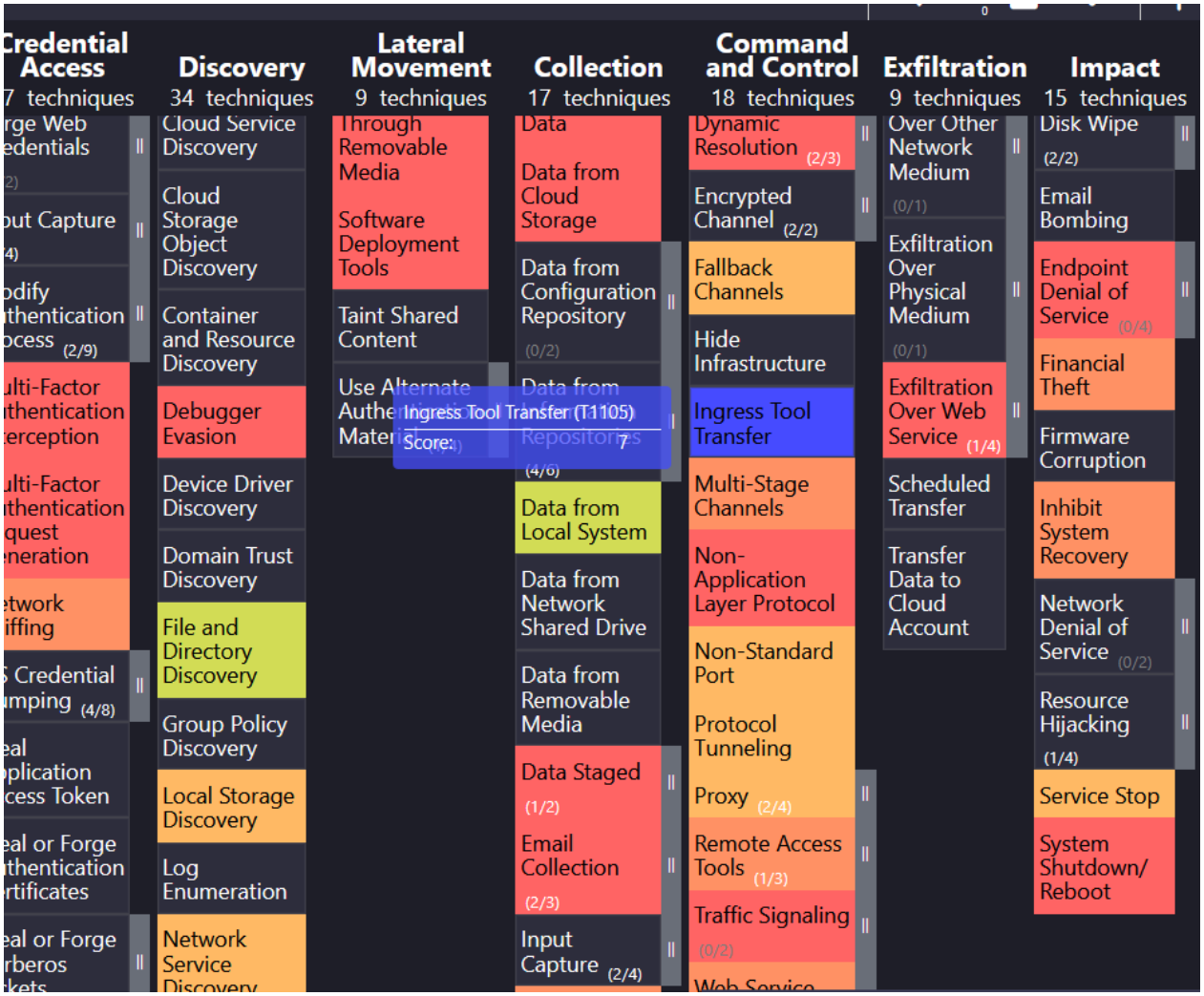
The following ATT&CK techniques were identified as the highest-overlap across the seven profiled actors. These represent the detection priorities for the financial sector threat landscape.

T-ID	Technique	Tactic	Overlap Score	Actors Using
T1105	**Ingress Tool Transfer**	Command and Control	**7/7 — ALL actors**	APT41, LAZARUS, KIMSUKY, SANDWORM, FIN7, TA505, Scattered Spider
T1078	**Valid Accounts**	Persistence / DA	**7/7 — ALL actors**	All actors leverage legitimate credentials post-compromise
T1059	**Command & Scripting Interpreter**	Execution	**7/7 — ALL actors**	PowerShell, cmd.exe, Python — universal execution technique
T1027	**Obfuscated Files or Information**	Defense Evasion	**6/7**	APT41, LAZARUS, KIMSUKY, FIN7, TA505, Scattered Spider
T1055	**Process Injection**	Defense Evasion	**6/7**	APT41, LAZARUS, SANDWORM, FIN7, TA505, KIMSUKY
T1003	**OS Credential Dumping**	Credential Access	**6/7**	APT41, LAZARUS, SANDWORM, FIN7, TA505, KIMSUKY
T1486	**Data Encrypted for Impact**	Impact	**5/7**	SANDWORM, FIN7, TA505, Scattered Spider, LAZARUS
T1041	**Exfiltration Over C2 Channel**	Exfiltration	**5/7**	APT41, LAZARUS, KIMSUKY, FIN7, TA505

T1071	**Application Layer Protocol (C2)**	Command & Control	6/7	All actors use HTTP/HTTPS C2; LAZARUS and APT41 abuse cloud services
T1021	**Remote Services**	Lateral Movement	6/7	APT41, LAZARUS, SANDWORM, FIN7, TA505, Scattered Spider
T1136	**Create Account**	Persistence	5/7	Financial sector identity creation for persistent access
T1204	**User Execution**	Execution	**7/7 — ALL actors**	All actors rely on user interaction with malicious content for delivery

Tactic-Level Overlap Summary

Tactic	InitialAccess	Execution	Persistence	Defense Evasion	CredentialAccess	LateralMovement	Exfiltration	C2	Impact
Actor Count	7	7	6	7	6	6	5	7	5



8. Detection Capability Recommendations

The following detection recommendations are derived directly from the overlap analysis. Each recommendation targets a technique with a high overlap score — meaning the detection will fire against multiple actors in the identified threat landscape. Recommendations are prioritised by overlap score (highest first) and include the data sources required, detection logic guidance, and the actors it will detect against.

8.1 Priority 1 Detections — 7/7 Overlap (Fire Against ALL Actors)

ATT&CK ID	Technique	Data Source Required	Detection Logic	Covers Actors
T1566	**Phishing**	Email gateway logs, endpoint process execution logs	Alert on: email with weaponised attachment execution; macro execution from Office; link to newly registered domain	**All 7 actors**
T1078	**Valid Accounts**	Identity provider logs, AD login events (Event ID 4624/4625)	Alert on: login outside business hours; impossible travel; login from new	**All 7 actors**

			device/location; sudden privilege use	
T1059	**Command Interpreter**	Windows Event Log (4688), EDR process telemetry	Alert on: PowerShell -EncodedCommand; cmd.exe spawned by Office process; WMIC executing remote processes	**All 7 actors**
T1204	**User Execution**	Email gateway, endpoint process telemetry, EDR	Alert on: Office macro execution; script execution from email attachment; user opening ISO/LNK from web download	**All 7 actors**

8.2 Priority 2 Detections — 6/7 Overlap

ATT&CK ID	Technique	Data Source Required	Detection Logic	Covers Actors
T1003	**Credential Dumping**	EDR, Sysmon Event 10 (LSASS access)	Alert on: LSASS memory access by non-system processes; secretsdump.py execution; Mimikatz signatures	**6/7 actors**
T1055	**Process Injection**	Sysmon Event 8 (CreateRemoteThread), EDR	Alert on: remote thread creation into lsass.exe, svchost.exe, explorer.exe; reflective DLL injection signatures	**6/7 actors**
T1027	**Obfuscation**	Process execution logs, email gateway, SIEM	Alert on: base64 encoded PowerShell commands; high entropy strings in process arguments; VBA macro obfuscation	**6/7 actors**
T1071	**C2 over HTTP/HTTPS**	Network proxy logs, DNS query logs, NDR	Alert on: beaconing behaviour (regular interval outbound connections); C2 over CDN; DNS tunnelling patterns	**6/7 actors**
T1021	**Remote Services**	Windows Security Event 4624 (Type 3), firewall logs	Alert on: lateral RDP from non-admin workstations; SMB lateral movement; unexpected WinRM usage	**6/7 actors**

8.3 Financial Sector-Specific Detection Rules

- SWIFT/CHIPS Anomaly Detection: Alert on SWIFT message modification (T1565 — Data Manipulation); out-of-hours wire transfer authorisation; new payee accounts created by privileged users (LAZARUS GROUP primary TTP)
- Identity Provider Abuse: Alert on Okta/Azure AD conditional access bypass; new MFA method enrolled from unrecognised device; help desk password reset without prior user contact (Scattered Spider primary TTP)
- Ransomware Pre-Deployment Indicators: Alert on Volume Shadow Copy deletion (vssadmin delete shadows); inhibit system recovery commands; mass file encryption activity (TA505/Clop primary TTP)

- Reinsurance Data Exfiltration: Data Loss Prevention (DLP) alert on bulk export of actuarial or treaty data; anomalous access to reinsurance contract databases outside business hours (APT41 intelligence collection)

9. Proactive Threat Hunting Use Cases

The overlap analysis directly generates proactive threat hunting hypotheses — structured, testable questions that a threat hunter can investigate in SIEM, EDR, and network logs. Each use case below is derived from a high-overlap TTP and is scoped to the financial services threat landscape.

#	Hunt Hypothesis	Data Sources & Search Logic	Relevant Actor TTPs
H-1	**A threat actor has established a low-and-slow beaconing C2 channel from an internal financial system to external infrastructure using HTTPS (T1071.001)**	Query: proxy/firewall logs for outbound HTTPS connections at regular intervals (e.g. every 60s ±5s) to newly registered or low-reputation domains. Filter: exclude known-good CDNs. Time window: 30-day lookback.	APT41, LAZARUS, KIMSUKY, FIN7, TA505 — all use HTTPS-based C2
H-2	**An attacker has abused valid account credentials to authenticate to financial systems outside normal business hours and from a new geographic location (T1078 — Valid Accounts)**	Query: Identity provider logs (Azure AD, Okta) for login events between 23:00–06:00 local time OR from a country not previously associated with the user account. Correlate with HR system for business travel context.	Scattered Spider, FIN7, LAZARUS — credential abuse is universal across all actors
H-3	**A threat actor has performed credential dumping against LSASS to harvest domain credentials for lateral movement within the financial institution (T1003.001)**	Query: Sysmon Event ID 10 for access to lsass.exe by a non-SYSTEM process. Filter: exclude AV/EDR vendor processes. Correlate with subsequent login events (Event 4624) from the same host.	APT41, LAZARUS, SANDWORM, FIN7, TA505, KIMSUKY — 6/7 actors use this technique
H-4	**A ransomware pre-deployment actor has deleted volume shadow copies and disabled backup agents as a precursor to encryption (T1490 — Inhibit System Recovery)**	Query: Windows Event Log / EDR for execution of vssadmin.exe delete shadows, wbadmin.exe delete catalog, or bcdedit.exe /set recoveryenabled no. Alert immediately — these are terminal indicators preceding encryption.	TA505/Clop, SANDWORM — ransomware pre-encryption checklist

10. Strategic Intelligence Assessment

10.1 Threat Landscape Overview — Insurance & Financial Services

The insurance and financial services sector faces a uniquely complex threat landscape driven by three converging factors: the high financial value of direct theft operations (motivating criminal actors), the geopolitical and intelligence value of financial data (motivating nation-state actors), and the systemic importance of the sector to national economies (making it a target for disruptive operations). No other sector simultaneously faces the full spectrum of financially motivated, espionage-driven, and destructive threat actors at scale.

Strategic Finding	Assessment
SF-01: Convergence of actor types	Nation-state actors (LAZARUS, APT41) and criminal actors (FIN7, TA505) increasingly share tooling and techniques — nation-state-developed malware is adopted by criminal groups, and criminal infrastructure is leveraged by state actors. This blurs attribution and means financial sector defenders must assume both motivational types operate simultaneously.
SF-02: Insurance sector as both target and victim	The insurance sector faces a dual risk: as a direct target (for policyholder PII, underwriting data, and reinsurance intelligence) and as an indirect victim (insuring organisations attacked by the same threat actors). The rising frequency and severity of cyber claims is a direct consequence of the threat actors profiled in this report.
SF-03: Identity is the new perimeter	The highest-overlap technique across all seven actors is Valid Accounts (T1078) — adversaries universally prefer to log in rather than break in. The financial sector's reliance on cloud identity providers (Azure AD, Okta) creates a single point of failure that Scattered Spider has specifically weaponised.
SF-04: Geopolitical escalation = financial sector risk	SANDWORM's NotPetya demonstrated that geopolitical cyber conflict has direct financial sector consequences even when financial institutions are not the intended primary target. Escalation in any major geopolitical conflict (Russia-Ukraine, US-China, US-North Korea) should trigger elevated alert levels across the financial sector.
SF-05: SWIFT and payment infrastructure remain primary nation-state targets	LAZARUS GROUP has demonstrated sustained operational interest in SWIFT network access since 2016. No fundamental security improvement to the financial messaging ecosystem has eliminated this risk — it represents the single highest-consequence attack vector for the sector.

11. Key Findings

#	Finding	Detail & Implication
F-01	**7/7 overlap on Phishing (T1566) makes email security the single highest-ROI control**	Every identified threat actor uses phishing as a primary or secondary initial access vector. A mature email security programme — advanced anti-phishing, attachment sandboxing, DMARC enforcement, and user training — provides detection and prevention coverage against 100% of the profiled threat landscape.
F-02	**The TTP overlap analysis enables adversary-agnostic detection**	Organisations no longer need to build separate detection rules for each APT group. The 12 highest-overlap techniques, when fully detected, provide coverage across all seven profiled actors regardless of which specific adversary initiates an attack — dramatically improving detection efficiency.
F-03	**Scattered Spider represents an emerging and underestimated insurance sector threat**	Unlike traditional APTs that exploit technical vulnerabilities, Scattered Spider's social engineering and identity abuse techniques are specifically designed to bypass controls that financial institutions have invested heavily in. Insurance companies' IT helpdesk functions are a specific, documented attack target.
F-04	**SOCRadar.io + MITRE ATT&CK creates a repeatable, scalable threat intelligence workflow**	The combination of SOCRadar's threat actor database (for actor identification and prioritisation) with MITRE ATT&CK's technique framework (for TTP analysis) and the Navigator (for overlap visualisation) constitutes a complete, tool-supported threat intelligence workflow that can be repeated quarterly to maintain current intelligence.
F-05	**Strategic intelligence gaps exist in reinsurance and underwriting sector threat understanding**	While banking and retail financial services have mature threat intelligence communities (FS-ISAC), the reinsurance and specialist underwriting sub-sectors have limited sector-specific threat intelligence sharing. APT41 and KIMSUKY's interest in treaty and actuarial data represents an underappreciated threat vector for this sub-sector.

12. Screenshot Evidence Index

#	Screenshot Caption	Section	Tool / Source
1	SOCRadar.io — Threat Actor Search Results (Financial Services Filter)	5.1 — SOCRadar Search	SOCRadar.io Platform
2	SOCRadar.io — Individual APT Profile (e.g. LAZARUS GROUP)	5.2 — APT Shortlisting	SOCRadar.io Platform
3	MITRE ATT&CK — APT41 Technique Page (G0096)	6.1 — APT41 Profile	attack.mitre.org
4	MITRE ATT&CK — LAZARUS GROUP Technique Page (G0032)	6.2 — LAZARUS Profile	attack.mitre.org
5	MITRE ATT&CK — FIN7 / TA505 / Scattered Spider Group Pages	6.5–6.7 — eCrime Profiles	attack.mitre.org
6	ATT&CK Navigator — All 7 Individual Layers Listed (Layer Panel)	7.1 — Individual APT Layers	ATT&CK Navigator
7	ATT&CK Navigator — Individual Layer Example (LAZARUS GROUP Highlighted)	7.1 — Individual Layers	ATT&CK Navigator
8	ATT&CK Navigator — Composite Overlap Layer (All 7 APTs Combined)	7.2 — Overlap Layer	ATT&CK Navigator
9	ATT&CK Navigator — Overlap Heatmap Detail (Highest-Overlap Techniques)	7.3 — Highest Priority TTPs	ATT&CK Navigator

End of Threat Intelligence Report

TLP:AMBER — Insurance & Financial Services Sector Threat Intelligence | MITRE ATT&CK Framework | SOCRadar.io